BUG BOUNTY PORTFOLIO

Ethical Hacking & Offensive Security

Saad

8 Projects Completed

90 Confirmed Findings

Executive Summary

This portfolio documents 8 offensive security projects covering the full attack lifecycle. A total of **90 confirmed findings** were validated across injection, server-side, deserialization, and cloud misconfiguration categories. All testing was performed on self-hosted labs and LocalStack.

Findings by Severity

Severity	Findings
CRITICAL	83
HIGH	7

Methodology

Phase 1 - Reconnaissance

Map the attack surface via subdomain enumeration, port scanning, technology fingerprinting.

Phase 2 - Vulnerability Discovery

Identify injection, server-side, client-side, and cloud vulnerabilities.

Phase 3 - Exploitation

Build minimal PoCs, demonstrate impact, document with screenshots, score CVSS.

Phase 4 - Reporting

Executive summary, technical details, prioritized remediation.

Phase 5 - Verification

Re-run exploits after patch, verify closure, test bypass variants.

Findings

Each of the 8 projects below includes vulnerability class, severity, tool built, and remediation.

#42 - SSRF Basic

Category: Web Exploitation

Vuln Class: CWE-918: Server-Side Request Forgery

Severity: HIGH (CVSS 8.1)

Tool: ssrf_toolkit.py

Findings: 7

Remediation: Whitelist URLs, block private IPs, disable dangerous protocols

#43 - XXE Advanced

Category: Web Exploitation

Vuln Class: CWE-611: Improper Restriction of XML External Entity Reference

Severity: CRITICAL (CVSS 9.1)

Tool: xxe_toolkit.py

Findings: 5

Remediation: Disable external entities, use defusedxml, disable DTDs

#44 - SSI Injection

Category: Web Exploitation

Vuln Class: CWE-94: Code Injection via SSI

Severity: CRITICAL (CVSS 9.8)

Tool: ssi_toolkit.py

Findings: 10

Remediation: Disable SSI, use IncludesNOEXEC, sanitize user input

#45 - LDAP Injection

Category: Web Exploitation

Vuln Class: CWE-90: LDAP Injection

Severity: CRITICAL (CVSS 9.0)

Tool: ldap_toolkit.py

Findings: 12

Remediation: Parameterized LDAP queries, escape special chars, whitelist input

#46 - NoSQL Injection

Category: Web Exploitation

Vuln Class: CWE-943: Improper Neutralization of NoSQL Operators

Severity: CRITICAL (CVSS 9.1)

Tool: nosql_toolkit.py

Findings: 19

Remediation: Validate input types, reject $-prefixed keys, use schema validation

#47 - SSRF Advanced (Blind + OOB)

Category: Web Exploitation

Vuln Class: CWE-918: SSRF with Blind OOB exfiltration

Severity: CRITICAL (CVSS 9.3)

Tool: ssrf_advanced_toolkit.py

Findings: 17

Remediation: Disable IPv6, block cloud metadata IPs, egress firewall

#48 - Deserialization (Java + Python)

Category: Advanced Attacks

Vuln Class: CWE-502: Deserialization of Untrusted Data

Severity: CRITICAL (CVSS 9.8)

Tool: deserialization_toolkit.py

Findings: 7

Remediation: Never deserialize untrusted data, use JSON, class whitelisting

#49 - Cloud Security (AWS/LocalStack)

Category: Cloud Security

Vuln Class: CWE-16: Cloud Misconfiguration (S3/IAM/SG)

Severity: CRITICAL (CVSS 9.5)

Tool: cloud_toolkit.py

Findings: 13

Remediation: Block public S3, enforce least-privilege IAM, restrict security groups

Conclusion

This portfolio demonstrates hands-on proficiency in offensive security across 8 projects and 90 confirmed findings. All testing was performed on self-hosted vulnerable labs, LocalStack, and intentionally vulnerable targets — no production systems were harmed.

Next Steps

* Pursue OSWE (Offensive Security Web Expert) certification
* Pursue OSCP (Offensive Security Certified Professional) certification
* Engage with HackerOne, Bugcrowd, and Intigriti platforms
* Expand coverage to API security, mobile, and Active Directory